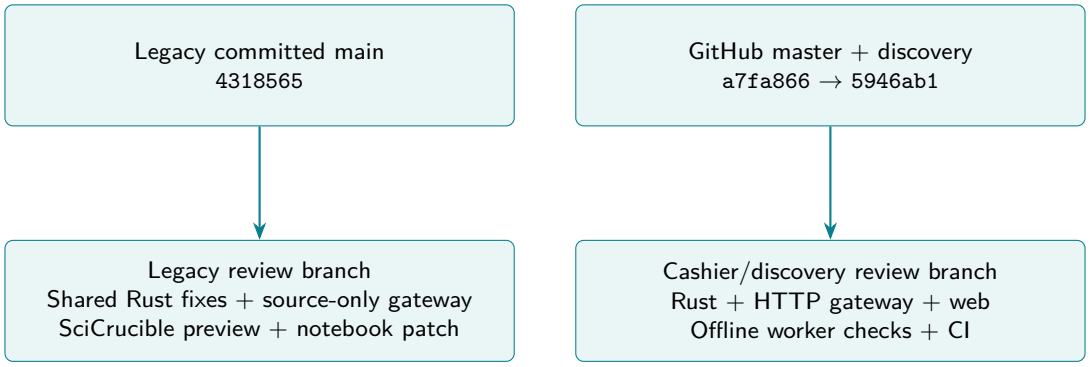
01 / DIRECTION

A stronger substrate, clearer boundaries

The project has a useful signed-artifact core, but its payment, storage and interface claims exceeded their implementation. This review repairs reproduced failures while preserving the two development lines and their source ownership.

Delivery: separate review branches, executable regressions, editable sources and this PDF. Passing software tests do not qualify science, settlement or production operation.

Two development lines



Source: Git ancestry and component paths in the two review checkouts. This is an architecture/ancestry figure, not scientific performance data.

What was included

Later line	`improve/reliability-20261023`: starts at `5946ab1`; retains four reviewed discovery commits beyond remote master.
Legacy line	`improve/legacy-main-20261025`: starts at committed `4318565`; imports selected gateway source from the modified checkout and applies bounded fixes.

Original checkouts were preserved. The legacy branch is **not a bulk snapshot** of the modified main tree. Notebook datasets, pilot records, scientific runs, environments and remaining uncommitted work were not imported.

Review coverage

Primary Rust/HTTP/UI paths, offline worker tests, contract scaffolds, and modified-main notebook/fulfillment code. Alternate landing pages, all historical outputs, deployed services, provider accounts and scientific validity were not exhaustively audited. Changed source identities are recorded in each branch's `SOURCE_MANIFEST.json`.

02 / IMPLEMENTED FIXES

Protect the evidence boundary

Failure	Repair and evidence
Forged signature	A weak identity public key and trivial signature passed verification. Strict Ed25519 verification now rejects the forgery; artifact/store/discovery regressions retain valid fixtures.
Store escape / overwrite	Canonical artifact IDs, filename/embedded-ID agreement, regular-file and symlink checks; complete bytes published atomically without replacement. Concurrent duplicate writes have one winner.
Worker identity / paths	DFT response IDs must match submitted IDs before cube writes. Digest filenames and exclusive creation prevent path escape and overwrite. Tests use fake workers.
Payment bypass	Arbitrary signature text no longer authorizes live x402 work. Requests fail closed and capability metadata says unavailable until real verification/settlement exists.
Wrong molecule	`C1CCCCC1` (cyclohexane) no longer matches `c1ccccc1` (benzene). Exact SMILES queries remain separate from normalized human labels.
Unbounded requests	Express IP trust rules replace raw forwarding headers. Rate state is bounded. MolADT process deadlines, output caps, concurrency caps and process-group cleanup have regression coverage.
Unhandled HTTP errors	Async rejection handling prevents revenue-log failures escaping Express 4. Containers run compiled JavaScript, without runtime `npx` downloads.
Checkout / fulfillment	Checkout API rejects unsupported minimum prices instead of silently increasing them. Legacy gateway adds serialized store operations and checkout-session idempotency.

Make the interface describe its actual behavior

Local state no longer claims submitted challenges, recomputation, wallet settlement or review completion. Fixture dates stay fixed. Checkout offers an intentional HTTPS link instead of an asynchronous popup that may be blocked. Legacy ORCID/submission/storage controls are explicitly unavailable previews.

Make build failures visible

Both frontends enforce TypeScript validation. Two suppressed legacy errors were repaired: an absent icon export and a nonexistent post field. Unused network font downloads were removed. CI checks Rust, gateway tests/types/build, frontends, and the later branch's offline Python workers.

Compatibility: store publication needs hard-link support and an operator-owned directory; `path_for` is fallible. Repeated cube filenames fail instead of overwriting; use a fresh per-run output directory.

03 / VERIFICATION

Checks with explicit limits

Check	Cashier / discovery	Legacy main
Rust workspace, all features	139 passed	89 passed
Gateway regressions	21 passed	24 passed
Gateway types / compiled build	Passed	Passed
Frontend types / production build	Passed; 3 static pages	Passed; 43 routes
Checkout URL tests	2 passed	Not applicable
Python 3.12 offline workers	70 literature + 10 guard/stub tests passed	Not imported
Notebook authorization patch	Not applicable	11 isolated checks passed

How these results were obtained

Rust used the installed macOS 15.2 SDK because the host's default SDK was incompatible with its linker. Initial dependency/cache/sandbox failures were resolved before the passing runs. Local Node was 25.9.0; CI targets Linux, Node 22 and Python 3.12. Local results do not establish hosted CI success.

Tests used fixtures and fake subprocesses. No scientific jobs, payment-provider transactions or deployments were performed. Independent inspection of the later branch found no blocking regression in the implemented fixes, with the reservations on the next page.

Notebook authorization patch: tested, not installed

The separately modified notebook routes omit authorization on three mutation surfaces. The legacy delivery contains a patch, an isolated verifier and source/patch hashes. It adds session/role checks and actor binding. Original data and code were preserved; the patch has not been applied there.

The same isolated harness accepted a synthetic artifact with invalid signature, key and hashes after JSON comparison. It labelled it ready for manual release. No payout occurred. This defect remains unresolved.

Publication and inspection limits

Candidate changed files produced no matching live-key/private-key patterns in a scoped credential scan; this is not a whole-history secret audit. Runtime data and local secrets were excluded from the source import. Docker image execution, browser interaction, hosted uptime, DNS and provider integration were not verified. No browser surface was connected for interactive inspection.

The PDF is built from editable LaTeX. Final pages were rendered and inspected separately; visual PDF review does not imply browser verification.

04 / REMAINING WORK

What the tests do not establish

1. **Notebook trust and concurrency.** Add cryptographic verification and authorized signer checks before accepting a correction. Replace read-modify-rename state with transactions. Define access policy for public GET routes and complete authentication integration.

2. **Cached artifact authenticity.** Gateway cache files remain trusted operator inputs. The stricter Rust verifier does not automatically validate the HTTP cache read path; add verification at ingestion or serving.

3. **Worker bounds outside the gateway.** Direct Rust DFT execution still waits without time/output limits. Current gateway process limits protect MolADT invocation only.

4. **Payment qualification.** Live x402 settlement and live DFT remain unavailable. A configured Payment Link proves neither successful payment nor delivery. Legacy fulfillment storage is a single-process design. Old credit ledgers need explicit reconciliation; failures after redemption need manual entitlement recovery. Exactly-once delivery is not claimed.

5. **Contract scaffolds.** Reputation can be set publicly; governor authorization does not enforce quorum or voting. No contract deployment, governance readiness or financial authorization is implied.

6. **Operational evidence.** Run hosted CI and container smoke checks, then qualify one bounded payment-to-artifact path with provider test accounts. Reconcile source/data ownership before merging the two histories.

Reproduce the software checks

```
cargo test -workspace -all-features -locked

# In services/api-gateway:

npm ci -ignore-scripts

npm run typecheck

npm test

npm run build

# In web or SciCrucible_v1:

npm ci -ignore-scripts

npm run typecheck

npm run build
```

Editable delivery

`REVIEW.md`, `REVIEW.tex`, `BUILD.sh`, source manifests and verification receipts travel with the branches. The legacy notebook patch includes its own isolated verification script and a receipt explicitly preserving the unresolved-signature finding.